Report

Insecure Authentication and Authorization
&
Insecure Communication

Suyash A Gunjal

Insecure Authentication

Insecure authentication happens when a mobile app does not properly verify a user's identity. Weak login mechanisms allow attackers to bypass authentication or gain access using stolen or guessed credentials.

Common Causes:

- Weak or no password policy
- Hardcoded credentials inside the app
- Insecure OTP or SMS-based verification
- No protection against brute-force attacks
- Storing credentials in plain text (Shared Preferences / local storage)

Impact:

- Unauthorized account access
- Account takeover
- Data theft and privacy violations

Example:
A mobile banking app allows unlimited login attempts without account lockout, enabling brute-force attacks.

Methods:

1. Weak or Improper Credential Management
   The application allows weak passwords, uses hardcoded credentials, or stores login details in plaintext. Attackers can easily extract or guess credentials.
2. Lack of Brute-Force and Rate-Limiting Protection
   The app does not limit login attempts or implement account lockout, enabling attackers to perform brute-force or credential-stuffing attacks.
3. Client-Side Authentication Logic
   Authentication checks are performed on the mobile app instead of the server. By modifying the app or requests, attackers can bypass login completely.

Insecure Authorization

Insecure authorization occurs when an app fails to properly check what an authenticated user is allowed to do. Attackers can access restricted features or data by manipulating requests.

Common Causes:

- Missing role-based access control (RBAC)
- Client-side authorization checks only
- Insecure or predictable user IDs
- Improper API permission validation

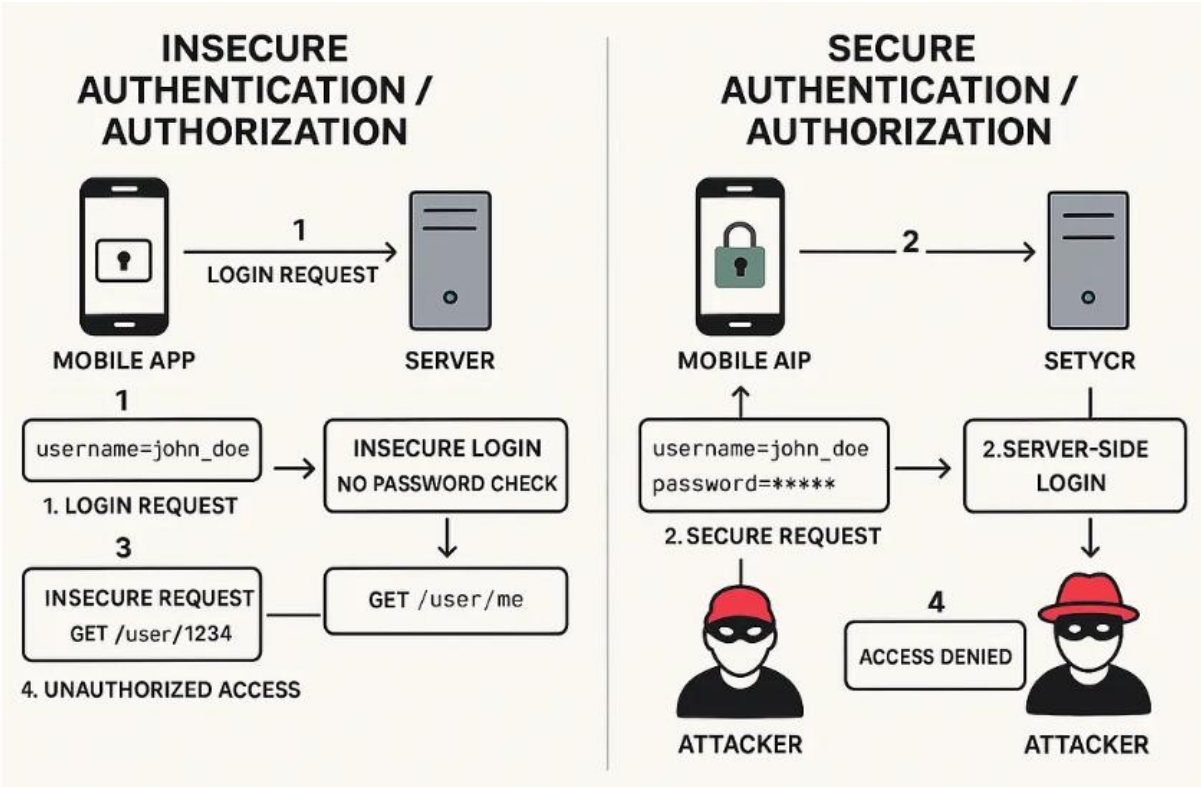
Impact:

- Privilege escalation
- Access to other users' data
- Unauthorized actions (delete, update, view)

Example:
A user changes the user Id parameter in an API request and accesses another user's profile.

Methods:

1. Missing Server-Side Authorization Checks
   The backend does not verify whether a logged-in user is allowed to access a specific resource or function, leading to unauthorized access.
2. Insecure Direct Object Reference (IDOR)
   The app uses predictable identifiers (userId, orderId). Attackers can change these values to access other users' data.
3. Improper Role or Privilege Management
   Role-based access control is not enforced properly, allowing normal users to perform admin-level actions (privilege escalation).



Insecure Communication

Insecure communication occurs when a mobile application transmits data between the client (mobile app) and the server without proper protection. This allows attackers to intercept, modify, or steal sensitive information during transmission.

Common Causes:

- Use of HTTP Instead of HTTPS
- Improper SSL/TLS Certificate Validation
- Absence of Certificate Pinning
- Use of Weak or Outdated Cryptography

Impact

- Credential theft
- Session hijacking
- Data manipulation
- Privacy breach

1.Lack of Proper Encryption (No HTTPS / Weak TLS)

The application transmits data over insecure channels or uses weak/outdated encryption protocols.

2.Improper Certificate Validation

The app does not properly verify SSL/TLS certificates, allowing attackers to perform Man-in-the-Middle (MITM) attacks.

3.No Certificate Pinning

Absence of certificate pinning allows attackers to intercept communication using forged or compromised certificates.

References:

https://owasp.org/www-project-mobile-top-10/2023-risks/m3-insecure-authentication-authorization

https://doverunner.com/blogs/insecure-authorization-and-impact-on-mobile-app-security/